Application-specific access policies using Zscaler Private Access(ZPA)

Team Member Details:

Name	Collage Name	Register No	Contact Details
SARAVANAN P	Sri Krishna Adithya Collage Of Arts And Science	2322K2921	23bscs252saravananp@skacas.ac.in
SANTHOSH S	Sri Krishna Adithya Collage Of Arts And Science	2322K2920	23bscs251santhoshs@skacas.ac.in
PRANEET M	Sri Krishna Adithya Collage Of Arts And Science	2322K2909	23bscs240praneetm@skacas.ac.in
PAVITHRAN V K	Sri Krishna Adithya Collage Of Arts And Science	2322K2908	23bscs239pavithranvk@skacas.ac.in
SANJAY PRASATH B	Sri Krishna Adithya Collage Of Arts And Science	2322K2917	23bscs248sanjayprasathb@skacas.ac.in

INTRODUCTION:

In an era where the digital landscape is constantly evolving, organizations face an ever-increasing threat from cyberattacks that leverage the inherent vulnerabilities of traditional network architectures. The need for swift and effective incident response has become paramount to safeguard sensitive data, protect digital assets, and maintain the trust of stakeholders in a highly competitive global market. In response to this growing challenge, this initiative presents a visionary project: the development of an AI-driven incident response platform that empowers cybersecurity teams with the tools to automate and enhance incident triage and response tasks. The necessity of this project is further highlighted by the obsolescence of the traditional network perimeter, which has been dissolved by the shift toward cloud computing and decentralized workforces.In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement once an initial breach occurs. To address these fundamental challenges, this project centers on the implementation of a Zero Trust security architecture, fundamentally operating on the principle of "never trust, always verify". By moving beyond location-based access, the organization aims to establish a security posture where trust is no longer implicit, and access is determined by granular context—including user identity, device health, and environmental attributes—rather than mere network connectivity.The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust Access solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users on the internal network, ZPA leverages a "service-initiated" model to establish direct, one-to-one connections between authorized users and specific applications, completely hiding the corporate network and IP address space from the internet. This ensures that users connect exclusively to the applications they are permitted to access, based on continuous identity verification and context, rendering the applications invisible to unauthorized users and preventing common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks.Ultimately, this project will enforce a least-privilege access model, ensuring users and devices are granted the minimum required access necessary to perform their functions. By decoupling application access from network access, the organization will eliminate the risk of lateral movement across the network, as users have no visibility or connectivity to other hosts beyond those explicitly authorized. This strategic move not only significantly enhances security by reducing the attack surface but also simplifies the user experience and reduces operational overhead associated with legacy remote access infrastructure, positioning the organization at the forefront of secure and efficient access management.

ABSTRACT:

The proliferation of hybrid work and cloud-based resources has rendered traditional perimeter-based security models, such as VPNs, obsolete and increasingly dangerous in a modern threat environment. These legacy solutions often provide overly broad network access, exposing organizations to significant risks including lateral threat movement, unauthorized reconnaissance, and an expanded attack surface. This project addresses these vulnerabilities by implementing a Zero Trust Architecture (ZTA) utilizing Zscaler Private Access (ZPA) as the primary broker for all internal application connectivity.The primary objective is to transition from network-centric to identity-centric access, thereby enforcing the principle of least privilege across all user populations. The methodology involves deploying ZPA's cloud-based service to create application-specific, identity-aware micro-tunnels. Unlike conventional VPNs that place users on the internal network, this solution establishes direct, one-to-one connections between verified users and authorized applications. The network infrastructure and all non-authorized applications remain completely invisible to the end-user, effectively eliminating the surface for reconnaissance and attack.Access policies are dynamically governed by user identity, device posture, and contextual attributes, ensuring that connectivity is strictly limited to what is explicitly required for specific job functions. The implementation of ZPA successfully decouples application access from network access, resulting in a demonstrable reduction in the organization's attack surface and the complete prevention of lateral movement. This project delivers a robust, scalable, and user-friendly remote access framework that aligns with modern security best practices. By shifting to an identity-aware, least-privilege model, the organization significantly enhances its security posture while simultaneously reducing operational complexity and improving the end-user experience across global locations.Use Case Scenarios

Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to access the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the Zscaler Client Connector, the device initiates an outbound connection to the Zscaler cloud. The user authenticates via Azure Active Directory, which is integrated with the ZPA platform, utilizing multi-factor authentication (MFA) to ensure identity integrity.ZPA evaluates the user's identity, group membership (Finance_ERP_Users), device posture (ensuring antivirus is active and disk encryption is enabled), and connection context. The policy engine determines that the user is authorized and brokers a secure, direct micro-tunnel to the ERP application only. The user can interact with the ERP interface with optimized performance, but has no visibility or network-level access to any other internal systems, such as development servers or the HR database.

Output:

User authenticated and authorized based on identity and group membership.Direct micro-tunnel established specifically to the ERP application.All other internal applications and network segments remain invisible and inaccessible.

Scenario 2: Contractor Access to Specific Project Repository

An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_X_Contractors" group. When the contractor connects using the Zscaler Client Connector, the system verifies their identity and checks the device for basic security compliance, such as OS patch levels and active firewalls.ZPA enforces a policy that grants access exclusively to the Git repository application (e.g., port 22/SSH or port 443/HTTPS) during business hours (9 AM to 5 PM). The contractor can clone, push, and pull code, but cannot discover or connect to any other internal resources, including the corporate intranet or file servers. This prevents the contractor from moving laterally within the network should their endpoint become compromised.

Output:

Time-bound and role-specific access enforced.Contractor restricted to a single application (Git repository).Lateral movement to adjacent systems completely blocked.

Scenario 3: Executive Access to Confidential Board Documents

A company executive needs to access a confidential folder containing board meeting materials hosted on an internal file server. The executive connects from a tablet device while traveling internationally. ZPA integrates with the mobile device management (MDM) solution to verify that the tablet is compliant, ensuring the device is not jailbroken and has encryption active.Upon successful authentication, ZPA evaluates the policy: "If user is in 'Executive_Board' group AND device is MDM-compliant AND connection is from a trusted country (allowlist), THEN grant access to 'Board_Documents' application". The executive is connected directly to the specific file share, and all data in transit is encrypted via TLS. Any attempt to access other shares or network resources is automatically blocked and logged for auditing purposes.

Output:

Context-aware access based on user role, device posture, and geographic location.Granular access to a specific file share (Board_Documents).Comprehensive logging of access events for audit and compliance.

Scenario 4: IT Administrator Access to Server Management Interfaces

A systems administrator requires access to management interfaces (SSH for Linux servers and RDP for Windows servers) to perform routine maintenance. Instead of granting VPN access to the entire management network, which would expose a massive attack surface, ZPA is

configured to treat each server or management interface as a separate application segment.The administrator authenticates and is presented only with the specific servers they are authorized to manage based on their IT subgroup (e.g., "Linux_Admins" see only Linux servers; "Windows_Admins" see only Windows servers). When the admin connects via SSH to a Linux server, ZPA creates a direct micro-tunnel to that specific IP and port combination. The admin cannot scan the subnet, access other servers, or initiate connections to non-authorized ports, effectively neutralizing the risk of accidental or malicious network-wide disruption.

Output:

Micro-segmentation at the individual server/interface level.Role-based access controlling visibility of specific management consoles.Elimination of network-level reconnaissance capabilities for admins.

Scenario 5: Mergers and Acquisitions Integration

A company acquires a smaller firm and needs to provide the acquired company's HR team with temporary access to the parent company's benefits enrollment application. The acquired company's users are added as external collaborators in the identity provider with limited attributes. ZPA policies are created that specifically grant the "Acquired_HR" group access only to the "Benefits_App" (a web application hosted internally).The acquired users install the Zscaler Client Connector, authenticate, and are connected directly to the benefits application. Because ZPA provides access without network connectivity, the parent company's entire internal network remains completely hidden and protected. The acquired users cannot ping, scan, or access any other corporate resource. After six months, when the integration is complete and users are migrated to the parent identity system, the temporary policies are revoked, eliminating the need for complex network de-provisioning.

Output:

Secure, temporary access provided without network exposure.Complete network invisibility protecting the parent company's infrastructure.Simplified deprovisioning through policy revocation rather than complex network changes.

Stage – 1

Title:

Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

Overview:

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these challenges, this project centers on the implementation of a Zero Trust security

architecture, fundamentally operating on the principle of "never trust, always verify". By moving beyond location-based access, the organization establishes a security posture where trust is no longer implicit, and access is determined by granular context rather than network connectivity.The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust Access solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users on the internal network, ZPA leverages a "service-initiated" model to establish direct, one-to-one connections between authorized users and specific applications, completely hiding the corporate network and IP address space from the internet. This ensures that users connect exclusively to the applications they are permitted to access, based on continuous identity verification and context, rendering the applications invisible to unauthorized users and preventing common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks.

List of Vulnerability:

The following table:

S. No	Vulnerability Name	CWE No.
1	Cross-site scripting (Stored)	79
2	Broken Access Control	285
3	SQL Injection	89
4	Broken Authentication	285
5	Insecure Direct Object Reference	639
6	Security Misconfiguration	732
7	Cross-Site Request Forgery (CSRF)	352
8	Cleartext Transmission of Sensitive Information	319
9	Clickjacking	1021
10	Web Server Allows Password Auto-Completion	310
11	Cross-site scripting (DOM-based XSS)	79
12	jQuery 1.2 < 3.5.0 Multiple XSS Vulnerabilities	79
13	Information Exposure (Web Server HTTP Header Internal IP Disclosure)	200
14	Information Exposure (SSL - Multiple Issues)	200

S. No	Vulnerability Name	CWE No.
15	Information Exposure (HTTP - Multiple Issues)	200
16	OS Identification Failed	200

Report:

Vulnerability name: Cross site scripting (stored) CWE: 79

OWASP category: A03:2021 -Injections

Description:

It occurs when a malicious script is injected directly into a vulnerable web application. Stored XSS, or Persistent XSS, occurs when a server-side application stores dangerous data in a database, message forum, or visitor log. Later, the dangerous data is read back into the application and included in dynamic content served to other users.

Business Impact:

The application stores dangerous data in a trusted data store. From an attacker's perspective, the optimal place to inject malicious content is in an area displayed to many users or those with elevated privileges. If an administrator executes the malicious script, the attacker may perform privileged operations or gain access to highly sensitive data.

Vulnerability path:

http://testfire.net/

Vulnerability parameter:

http://testfire.net/search.jsp?query=%27%3E%3Cscript%3Ealert%28%27hacked%27%29%3C%2Fscrip t%3E

Steps to Reproduce:

Access the URL.In the search box, input code to perform the vulnerability.The script used is '>alert('hacked').This displays a harmless pop up alert box with the text ‘hacked’, confirming script execution.

Recommendation:

When interacting with databases, use parameterized statements or prepared statements to avoid SQL injection, which can be a vector for XSS. Sanitize and validate all user inputs and ensure that any data displayed on the web page is properly encoded. Use output encoding libraries or functions to prevent script injection.

Vulnerability name: Broken access control CWE: 285

Description:

When access control checks are not applied consistently - or not at all - users are able to access data or perform actions that they should not be allowed to perform. This can lead to a wide range of problems, including information exposures, denial of service, and arbitrary code execution.

Business Impact:

Wide-ranging business impact, including financial losses, reputation damage, legal consequences, and operational disruption. Addressing this is crucial to protect the organization and its stakeholders from unauthorized access to sensitive functionality.

Vulnerability path:

http://testfire.net/

Vulnerability parameter:

http://testfire.net/login.jsp

Steps to Reproduce:

Access the URL.Attempt to sign in with administrative privileges.Use an intercepting proxy like Burp Suite to capture requests.Input ‘admin’ for both username and password.Capture the request in clear text, revealing credentials.Forward the request to access the admin user details.Observe the ability to edit other users' data or delete login details.

Recommendations:

Ensure that the application has a robust authentication and authorization mechanism in place. Users should be authenticated before any sensitive actions are performed. Ensure session management is secure, using strong session IDs and enforcing timeouts.

Vulnerability name: SQL injection CWE: 89

Description:

The product constructs all or part of an SQL command using externally-influenced input, but it does not neutralize or incorrectly neutralizes special elements that could modify the intended SQL command.

Business Impact:

SQL Injection can exert a profound impact, including data breaches, financial setbacks, and operational turmoil. Preventing these vulnerabilities is indispensable for fortifying the security of an organization's data.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/login.jsp

Steps to Reproduce:Access the URL.Attempt to sign in with admin privileges using SQL injection strings in the login fields.Utilize Burp Suite to capture and analyze the HTTP requests.Observe that the injection allows bypass of the authentication logic.Confirm successful login as admin without a valid password.

Recommendations:

Utilize parameterized statements or prepared statements for all database queries. If parameterized statements are not feasible, use proper input validation and escaping mechanisms. Implement strict input validation to ensure data adheres to the expected format.

Vulnerability name: Broken authentication CWE: 285

Description:

The system's authorization functionality does not prevent one user from gaining access to another user's data or record by modifying key values identifying the data.

Business Impact:

Rectifying these vulnerabilities is critical to safeguarding sensitive data and user identities. Mitigation should include multi-factor authentication and secure storage of credentials.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/login.jsp

Steps to Reproduce:

Access the URL.Attempt to login using a targeted username and a SQL injection string to bypass the password check.Observe direct access to the specific user’s account details without their password.

Recommendations:

Implement strong authentication mechanisms, such as multi-factor authentication (MFA). Use role-based access control (RBAC) to manage user privileges effectively. Deploy intrusion detection systems to monitor suspicious authentication activities.

Vulnerability Name: Insecure Direct object Reference CWE: 639

OWASP Category: A01: Broken Access Control

Description:

Insecure Direct Object Reference (IDOR) arises when attackers can access or modify objects by manipulating identifiers used in URLs or parameters. It occurs due to missing access control checks.

Business Impact:

Organizations must fortify access control to prevent unauthorized data manipulation. These measures are critical in defending sensitive data and preserving reputation.

Vulnerability Path: http://testfire.net

Vulnerability Parameter: http://testfire.net/bank/transfer.jsp

Steps to Reproduce:

Sign into the site.Navigate to “Transfer Money” and fill in details.Use an intercepting proxy to capture the transfer request.Modify the amount parameter (e.g., from 100 to 1000).Forward the modified request and observe the transaction reflects the unauthorized amount.

Recommendation:

Utilize parameterized queries when interacting with databases. Implement a Content Security Policy to mitigate XSS risks that could be used for unauthorized queries. Implement account lockout mechanisms after repeated unauthorized attempts.

Vulnerability name: Security Misconfiguration CWE: 732

Description:

The product specifies permissions for a security-critical resource in a way that allows that resource to be read or modified by unintended actors.

Business Impact:

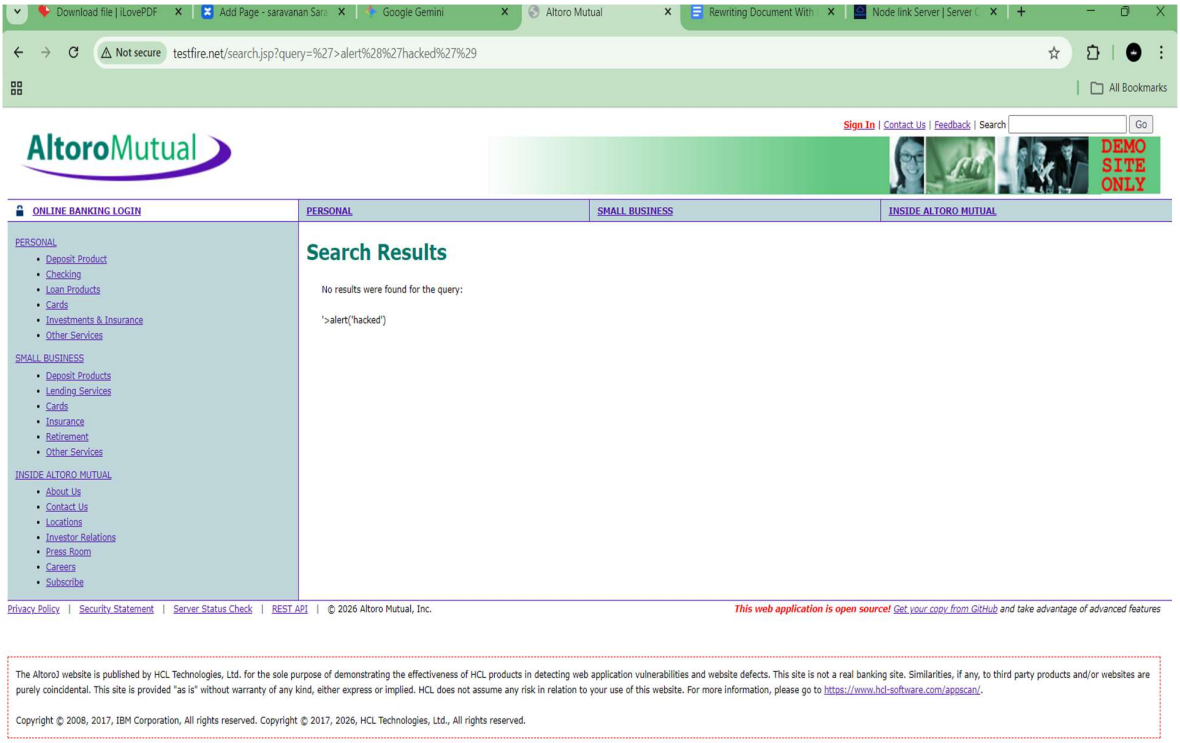
Organizations must emphasize configuration management, including secure default settings and routine evaluations.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/login.jsp

Steps to Reproduce:

Use scanning tools (e.g., Uniscan) to search for hidden directories.Identify directories that are accessible due to poor security configuration.Access a discovered webpage (e.g., job applications) to view sensitive data unintended for public access.



Recommendations:

Implement a change management process to document and review configuration changes. Follow security guidelines provided by vendors. Regularly perform compliance checks against industry standards.

Vulnerability Name: Cross-Site Request Forgery CWE: 352

OWASP Category: A08: Cross-Site Request Forgery

Description:

CSRF forces an end user to execute unwanted actions on a web application in which they are currently authenticated. Attackers use social engineering to trick victims into clicking malicious links.

Business Impact:

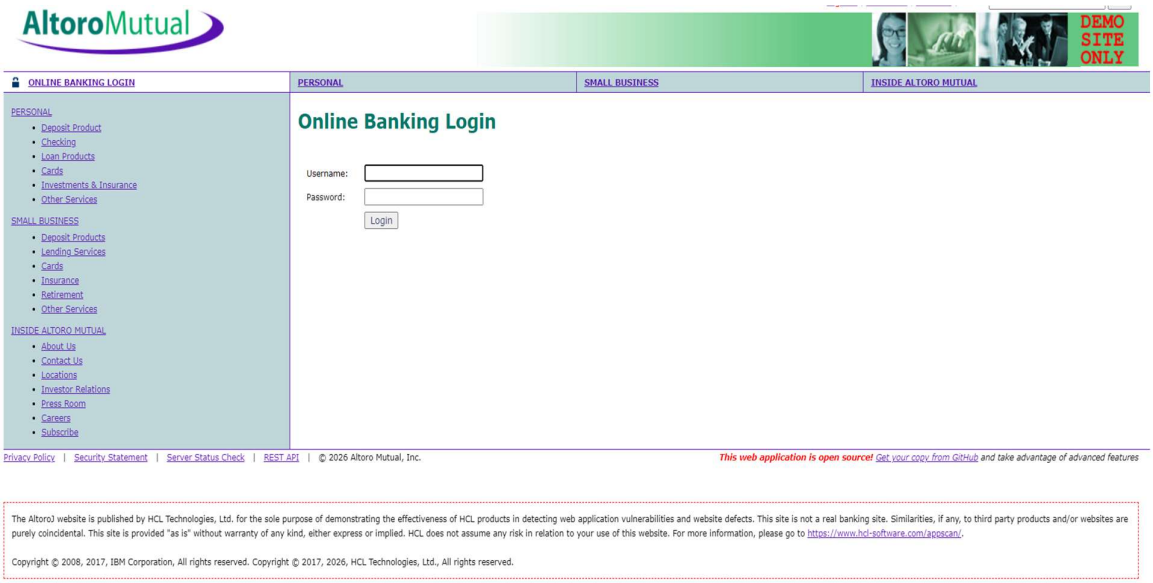
If an administrative account is targeted, CSRF can compromise the entire web application.

Vulnerability Path: http://testfire.net/

Vulnerability Parameter: http://testfire.net/bank/transfer.jsp

Steps to Reproduce:

Login to the site.Capture a transfer request in an intercepting proxy.Generate a CSRF Proof of Concept (PoC) using proxy tools.Tricked user clicks the malicious link while logged in.Observe that a transaction is performed automatically without the user's knowledge.



Recommendations:

Implement Synchronizer Token Patterns to include unique tokens in each HTTP request. Utilize the SameSite attribute in cookies to restrict usage to same-site requests. Implement a Content Security Policy to specify trusted sources of content.

Vulnerability name: Cleartext Transmission of Sensitive Information CWE: 319

Description:

The product transmits sensitive data in cleartext in a communication channel that can be sniffed by unauthorized actors.

Business Impact:

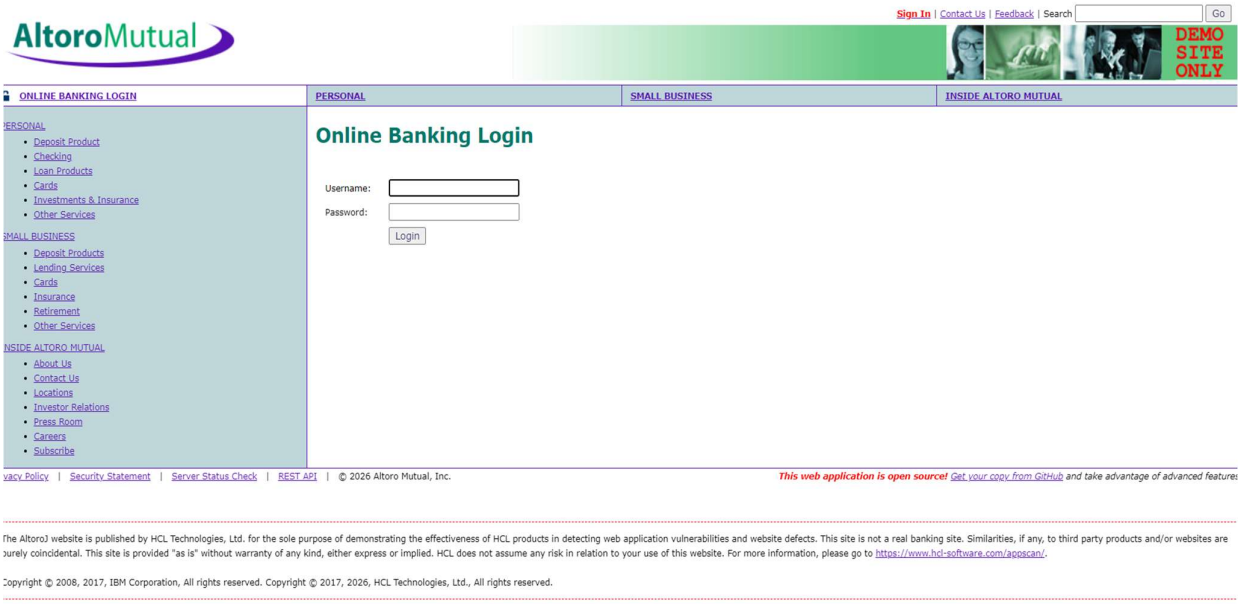
Network traffic could be sniffed, spilling security-critical data such as login credentials.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/login.jsp

Steps to reproduce:

Access the login page.Capture the login request in Burp Suite.Observe that the username and password are visible in clear text within the request body.



Recommendations:

Educate users on secure data handling and recognizing secure (HTTPS) websites. Implement encryption for data in transit using secure protocols like TLS/SSL. Use secure communication protocols for all sensitive transmissions.

Vulnerability name: Click Jacking CWE: 1021

Description:

The web application does not restrict frame objects, leading to user confusion about the interface they are interacting with.

Business Impact:

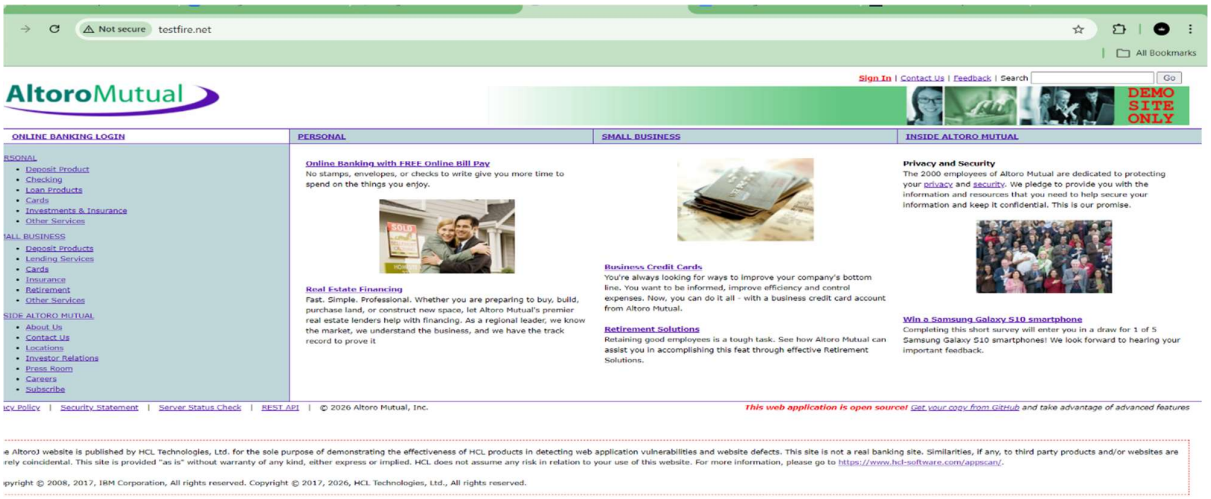
Organizations must prioritize protective measures like frame-busting code to prevent clickjacking.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/

Steps to reproduce:

Access the target URL.Create an HTML file using an iframe to embed the target site.Execute the code in a browser and observe that the site is successfully framed.



Recommendation:

Set the X-Frame-Options HTTP response header to 'deny' or 'same-origin'. Utilize frame-busting JavaScript code. Implement a Content Security Policy to restrict domain embedding.

Vulnerability name: web server allows password auto-completion CWE: 310

Description:

Weaknesses related to data confidentiality and integrity, such as improper password handling and encryption.

Business impact:

Adoption of secure cryptographic practices is essential for protecting sensitive data.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/login.jsp

Steps to reproduce:

Access the login URL.Observe that the browser auto-fills usernames and passwords.

Responsibilities:

Implement secure password storage using strong cryptographic hashing algorithms like bcrypt. Implement robust encryption key management. Use secure protocols like TLS for all data transmission.Vulnerability name: Cross-site scripting (DOM based XSS) CWE: 79

OWASP category: A03: Injections

Description:

Malicious script injection through manipulation of the Document Object Model (DOM).

Business Impact:

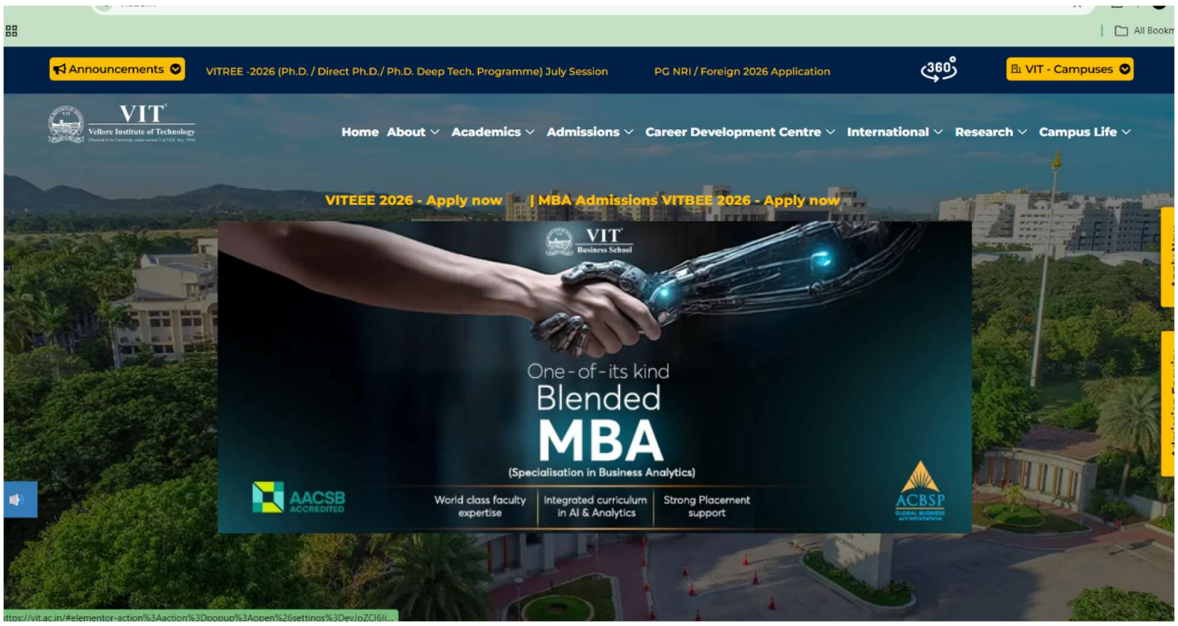
Attackers can execute malicious content to perform privileged operations on behalf of the user.

Vulnerability path: https://vit.ac.in/

Vulnerability parameter: https://vit.ac.in/

Steps to Reproduce:

Access the URL.Inspect the source code (Ctrl + U).Identify vulnerable spots in the client-side JavaScript that could be used for script injection.



Recommendation:

Sanitize and validate all user inputs and ensure proper output encoding. Avoid using DOM manipulation methods like innerHTML that can execute scripts. Use established JavaScript frameworks with built-in security features.

Vulnerability name: JQuery 1.2 < 3.5.0 Multiple XSS CWE: 79

OWASP category: A03: Injections

Description:

Involves the execution of malicious scripts due to vulnerabilities in outdated jQuery library versions.

Business Impact:

Compromise of data or sessions when users view affected content.

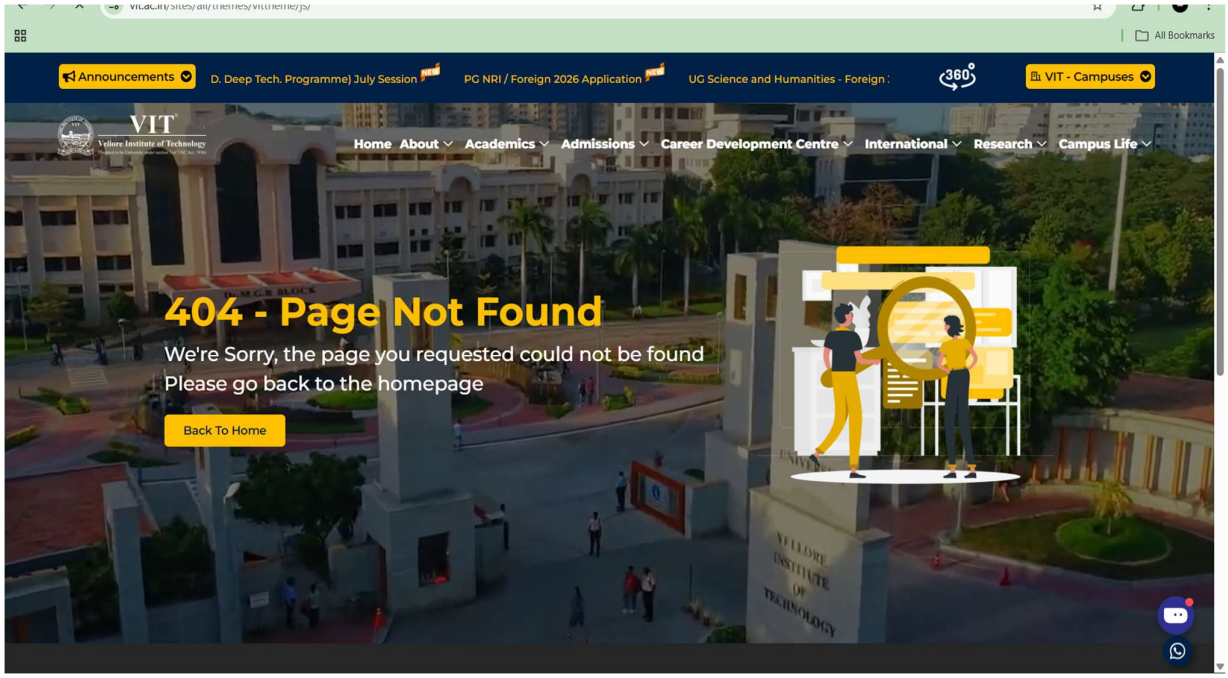
Vulnerability path: https://vit.ac.in/

Vulnerability parameter:

https://vit.ac.in/sites/all/themes/vittheme/js/jquery-2.1.1.min.js?rdiap4

Steps to Reproduce:

Access the jQuery script URL.Identify the outdated jQuery version (e.g., 2.1.1) used in the website.



Recommendation:

Update to the latest version of jQuery to include security patches. Implement a Content Security Policy (CSP) to restrict script sources.

Vulnerability name:

Information Exposure (Web Server HTTP Header Internal IP Disclosure) CWE: 200

Description:

Exposes sensitive internal network information to unauthorized actors.

Business Impact:

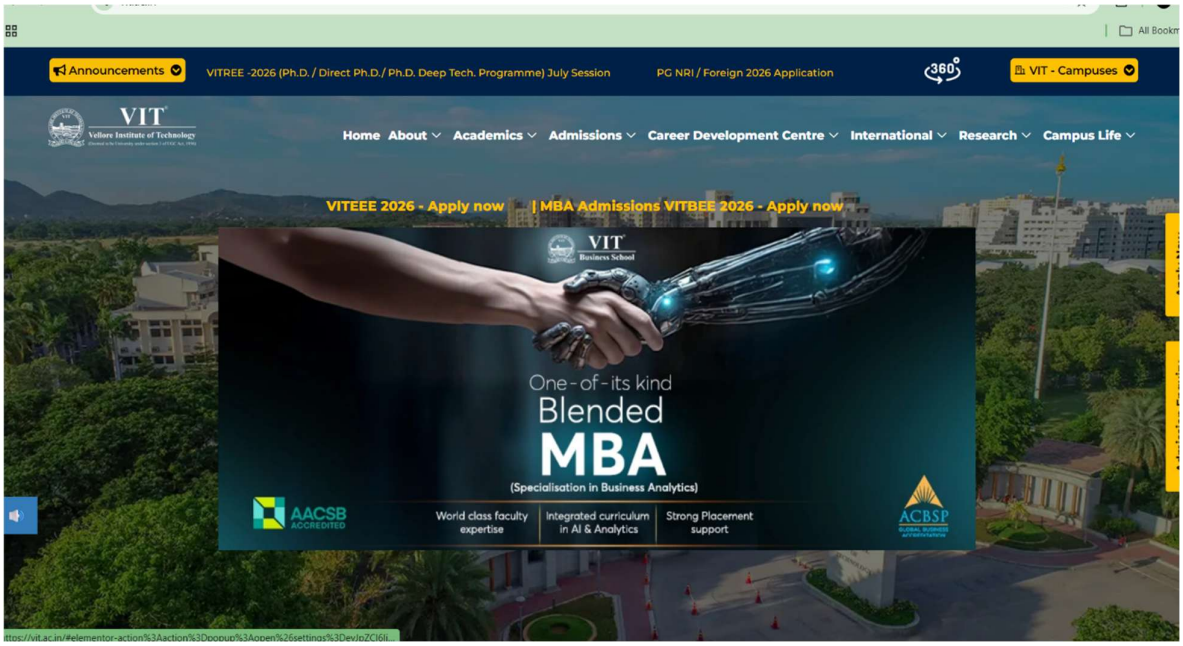
Facilitates internal network reconnaissance and targeted attacks.

Vulnerability path: https://vit.ac.in/

Vulnerability parameter: https://vit.ac.in/

Steps to Reproduce:

Perform a scan using a vulnerability scanner (e.g., Nessus).Review scan results for internal IP address disclosure in HTTP headers.



Recommendation:

Review web server configuration files to remove internal IP addresses from headers.
Configure load balancers to only expose public IP addresses.

Vulnerability name: Information Exposure (SSL (Multiple Issues)) CWE: 200

Description:

Exposes sensitive information through insecure SSL/TLS configurations.

Business Impact:

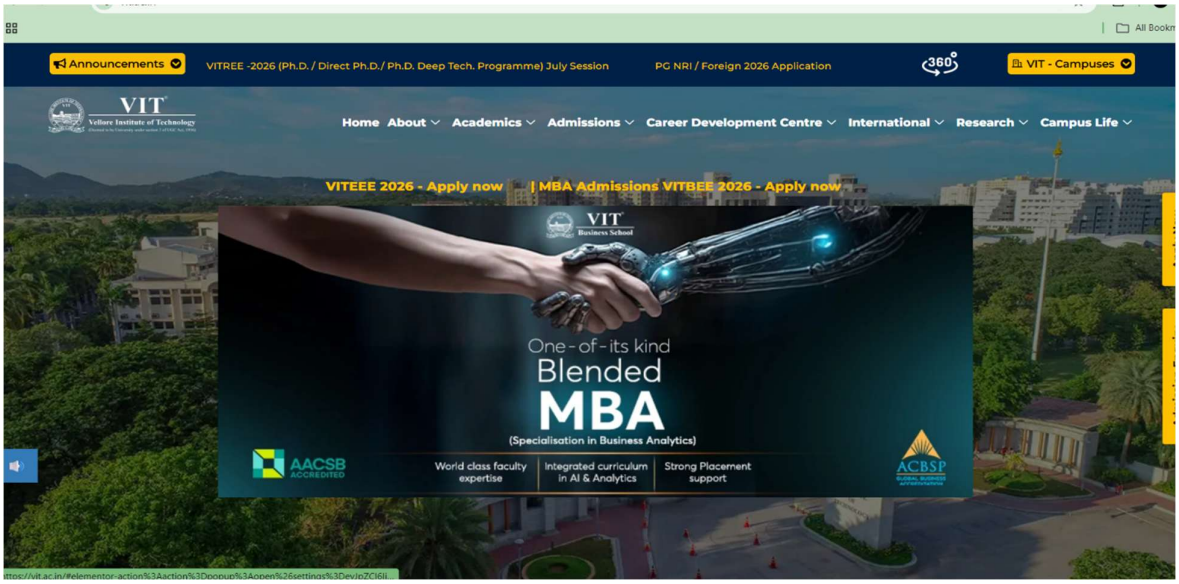
Upholding user trust requires secure cryptographic configurations.

Vulnerability path: https://vit.ac.in/

Vulnerability parameter: https://vit.ac.in/

Steps to Reproduce:

Perform a Nessus scan.Analyze the type of encryption and public key details disclosed.



Vulnerability path: https://vit.ac.in/

Vulnerability parameter: https://vit.ac.in/

Steps to Reproduce:

Use Nessus to identify protocol versions and remote webserver types.Identify unnecessary redirects or broken links.

Recommendation:

Minimize unnecessary redirects and fix broken links (404 errors). Migrate the website to HTTPS to ensure secure transmission.Vulnerability name: OS Identification Failed CWE: 200

Description:

Inability to accurately recognize the operating system, potentially leading to security gaps.

Business Impact:

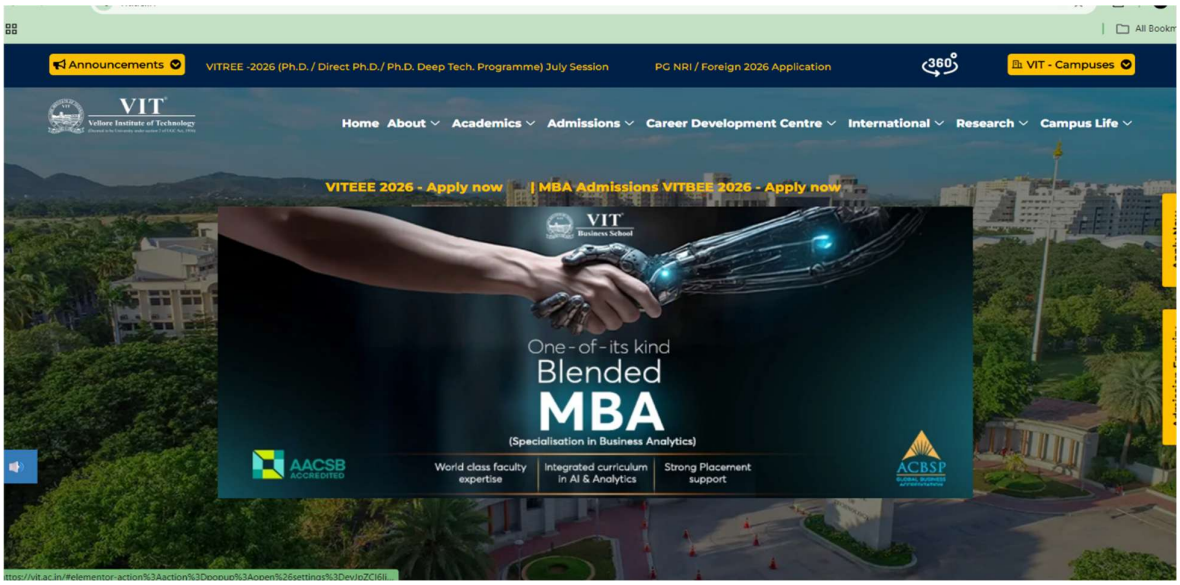
May result in operational inefficiencies and data security risks.

Vulnerability path: https://vit.ac.in/

Vulnerability parameter: https://vit.ac.in/

Steps to Reproduce:

Conduct a Nessus scan.Observe results indicating a failure to identify the remote OS.



Recommendations:

Employ robust data encryption and strict access controls. Conduct regular security audits to identify vulnerabilities.

Stage – 2

Overview:

An overview of a Nessus scan typically involves several key operational steps. Preparation involves defining objectives, determining scope, and ensuring necessary system access permissions. Configuration entails setting up scan policies (types of vulnerabilities, frequency) and defining target assets such as IP addresses or hostnames. During scanning, Nessus systematically identifies vulnerabilities, misconfigurations, and open ports, categorizing them by severity. Reporting provides detailed findings, including remediation steps and evidence. Remediation involves reviewing reports and taking corrective actions, such as applying patches or changing configurations. Regular scanning and integration with other security tools (e.g., SIEM) help maintain a strong security posture. Nessus is a plugin-based architecture, meaning it is regularly updated to support the latest security checks. It is widely used for vulnerability assessment, network scanning, and compliance auditing.

S. No	Vulnerability Name	Severity	Plugins
1	Cross-site scripting (Stored)	Low	Web Application Scanner
2	Broken Access Control	Medium	SSH Weak HMAC Algorithms Supported
3	SQL Injection	Medium	N/A
4	Broken Authentication	Low	HSTS Missing from Server
5	Insecure Direct Object Reference	Info	Service Detection
6	Security Misconfiguration	Low	SSL Cipher Block Chaining Cipher Suites
7	Cross-Site Request Forgery (CSRF)	Low	HTTP Form-Based Authentication Detected
8	Cleartext Transmission of Sensitive Information	Medium	Cleartext Transmission over HTTP
9	Clickjacking	Info	HTML Rendering Layer Vulnerability
10	Web Server Allows Password Auto-Completion	Low	SSL/TLS Diffie-Hellman Modulus ≤ 1024 bits

Website: testfire.netTarget

IP Address: 54.83.41.36

Report:

VULNERABILITY NAME: Cross site scripting (stored)

SEVERITY: Low

PLUGIN: web application scanner

PORT: N/A

DESCRIPTION:

Malicious script injection directly into a web application. Stored XSS involves persistent storage on the server.

SOLUTION:

Use parameterized statements and sanitize all user inputs.

BUSINESS IMPACT:

Potential for unauthorized operations if privileged users execute the script.

VULNERABILITY NAME: Broken access control

SEVERITY: medium

PLUGIN: SSH weak HMAC Algorithms supported

PORT: N/A

DESCRIPTION:

Users may perform actions or access data they should not be allowed to reach.

SOLUTION:

Implement robust authentication and authorization mechanisms.

BUSINESS IMPACT:

Reputation damage and operational disruption.

VULNERABILITY NAME: SQL injection

SEVERITY: medium

PLUGIN: N/A (Security Testing Context)

PORT: port 80/443

DESCRIPTION:

Manipulation of SQL commands through un-neutralized input.

SOLUTION:

Utilize parameterized queries or stored procedures.

BUSINESS IMPACT:

Data breaches and legal ramifications.VULNERABILITY NAME: Broken authentication

SEVERITY: Low

PLUGIN: HSTS Missing from HTTPS Server (142960)

PORT: port 443

DESCRIPTION:

Authorization flaws that allow one user to access another's data.

SOLUTION:

Implement multi-factor authentication (MFA).

BUSINESS IMPACT:

Compromised user identities and security posture.

VULNERABILITY NAME: Insecure Direct object Reference

SEVERITY: Info

PLUGIN: Service Detection (22964) PORT: port 80/443

DESCRIPTION: Accessing objects by manipulating identifiers in URLs.

SOLUTION: Use prepared statements and account lockout mechanisms.

BUSINESS IMPACT:

Critical defense requirement for sensitive data.

VULNERABILITY NAME: Security Misconfiguration

SEVERITY: low

PLUGIN: SSL cipher Block chaining cipher suites

PORT: port 443

DESCRIPTION:

Permissions specified in a way that allows unintended access to resources.

SOLUTION:

Document configuration changes and follow vendor guidelines.

BUSINESS IMPACT:

Essential for safeguarding system security.

VULNERABILITY NAME: Cross-Site Request Forgery

SEVERITY: Low

PLUGIN: HTTP Form-Based Authentication Detected

PORT: port 8080/443

DESCRIPTION:

Forcing end users to execute unwanted actions while authenticated.

SOLUTION:

Implement Synchronizer Token Patterns and SameSite attributes.

BUSINESS IMPACT:

Potential for unauthorized transactions.

VULNERABILITY NAME: Cleartext Transmission of Sensitive Information
SEVERITY: Medium

PLUGIN: Cleartext Transmission over HTTP PORT: port 443

DESCRIPTION:

Transmitting sensitive data in a monitorable cleartext channel.

SOLUTION:

Implement TLS/SSL for all data in transit.

BUSINESS IMPACT:

Spilling of security-critical information.

VULNERABILITY NAME: Clickjacking

SEVERITY: Info

PLUGIN: HTML Rendering Layer Vulnerability

PORT: port 80/443

DESCRIPTION:

User interface layers that confuse users about interactions.

SOLUTION:

Set X-Frame-Options to 'deny' or 'same-origin'.

BUSINESS IMPACT:

Affects user trust and data protection.VULNERABILITY NAME: web server allows password auto-completion

SEVERITY: Low

PLUGIN: SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

PORT: port 443

DESCRIPTION:

Design flaws in data confidentiality and implementation.

SOLUTION:

Implement robust encryption key management and hashing.

BUSINESS IMPACT:

Essential for preserving organization reputation.The following table:

S. No	Vulnerability Name	Severity	Plugins
1	Cross-site scripting (DOM-based XSS)	Medium	Multiple XSS
2	jQuery 1.3 < 3.5.0 Multiple XSS	Medium	CGI Abuse: XSS
3	Information Exposure (Internal IP Disclosure)	Low	Web Server Header IP Disclosure
4	Information Exposure (SSL Issues)	Info	SSL Certificate Information
5	Information Exposure (HTTP Issues)	Info	HTTP Information
6	OS Identification Failed	Info	TCP/IP Remote Probing

Report:

VULNERABILITY NAME: Cross-site scripting (DOM based XSS)
SEVERITY: Medium

PLUGIN: Multiple XSS

PORT: port 443

DESCRIPTION: Injection via DOM manipulation, representing potential content structure changes.

SOLUTION: Avoid dangerous DOM manipulation methods and use secure libraries.

BUSINESS IMPACT:

Privileged operation bypass if executed by sensitive users.

VULNERABILITY NAME: jQuery 1.2 < 3.5.0 Multiple XSS

SEVERITY: Medium

PLUGIN: CGI Abuse: XSS

PORT: port 443

DESCRIPTION:

Exploits in outdated jQuery libraries for script execution.

SOLUTION:

Update jQuery and implement a Content Security Policy (CSP).

BUSINESS IMPACT:

Compromised data and sessions for viewing users.

VULNERABILITY NAME: Information Exposure (Internal IP Disclosure)

SEVERITY: Low

PLUGIN: Web Server HTTP Header Disclosure

PORT: port 80

DESCRIPTION:

Revelation of internal network addresses in HTTP headers.

SOLUTION:

Review server configuration files and use appropriate placeholders.

BUSINESS IMPACT:

Critical for safeguarding internal network topology.

VULNERABILITY NAME: Information Exposure (SSL (Multiple Issues))
SEVERITY: Info

PLUGIN: SSL certificate Information

PORT: port 443

DESCRIPTION: Exposure through authorized but sensitive SSL configuration details.

SOLUTION:

Disable outdated protocols like SSLv3 and implement PFS.

BUSINESS IMPACT:

Preserving reputation and user trust.

VULNERABILITY NAME: Information Exposure (HTTP (Multiple Issues))

SEVERITY: Info

PLUGIN: HTTP information

PORT: port 80 /443

DESCRIPTION:

Sensitive data exposure via HTTP status or protocol details.

SOLUTION:

Properly configure CORS and migrate to HTTPS.

BUSINESS IMPACT:

Continuous enhancement required for secure online presence.

VULNERABILITY NAME: OS Identification Failed

SEVERITY: Info

PLUGIN: TCP/IP remote probing

PORT: N/A

DESCRIPTION:

System inability to recognize the underlying operating system.

SOLUTION:

Employ encryption and strict authentication protocols.

BUSINESS IMPACT:

Potential for operational inefficiencies and security gaps.

Stage – 3

Title:

Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is a cybersecurity framework that shifts access control from a network-centric model to an identity-centric model. The foundational principle is "never trust, always verify," meaning that no user or device is trusted by default. ZTNA creates application-specific tunnels, effectively shrinking the attack surface.

Zscaler Private Access (ZPA)

Zscaler Private Access (ZPA) is a cloud-delivered ZTNA solution providing identity- and context-based access. ZPA operates on a service-initiated model where users connect to the Zscaler cloud, which brokers a secure connection via App Connectors. This hides internal IP addresses and network infrastructure from the public internet.

Principle of Least Privilege

The principle of least privilege (PoLP) ensures users are granted the minimum level of access necessary for their function. Through ZPA, organizations move from "fat" network access to "thin," application-specific access. This limits the blast radius of potential incidents.

Identity-Aware Access

Identity-aware access bases decisions on who the user is, utilizing integrations with identity providers (IdPs) like Azure AD or Okta. Policies leverage existing user attributes and group memberships to build granular rules.

Application-Specific Access Policies

Administrators define policies for individual applications rather than entire subnets. This micro-segmentation ensures that access for one application provides no visibility into another.

ZPA Architecture and Components

The ZPA architecture includes the Zscaler Cloud (Service Edge), lightweight App Connectors, the Zscaler Client Connector, and Application Segments. App Connectors establish outbound-only connections to the Zscaler cloud.

Implementation Methodology

The deployment follows a structured approach: Discovery and Inventory (identifying apps), Connector Deployment (provisioning VMs), Application Onboarding (defining segments), Policy Creation (integrating with IdP), Pilot and Rollout (testing with users), and VPN Decommissioning.

Tools and Technologies

Primary Platform:

Zscaler Private Access (ZPA). Identity Providers include Microsoft Azure AD and Okta. Endpoint Protection Platform (EPP) integration includes CrowdStrike and SentinelOne. SIEM integration covers IBM QRadar and Splunk.

Integration with Identity Providers

Integration is typically achieved via SAML or SCIM protocols. This allows ZPA to synchronize user attributes and enforce multi-factor authentication (MFA)

.Device Posture Checking

ZPA enforces policies based on antivirus status, disk encryption, OS patch level, and real-time risk scores from EDR tools.

Micro-tunneling and Application Visibility

ZPA establishes TLS/DTLS tunnels, ensuring Layer 7 proxying. Internal resources remain invisible, preventing reconnaissance.

Threat Intelligence Integration

Logs are forwarded to SIEM systems and correlated with threat intelligence feeds to identify suspicious behavior.

Incident Response in a ZPA Environment

ZPA streamlines response through immediate access revocation, detailed forensics, and blast radius containment.

Conclusion:

Stage 1:

Web application testing is a crucial process ensuring security and functionality, bolstering resilience against vulnerabilities.

Stage 2:

The Nessus report provides clear guidance on mitigating vulnerabilities and stresses sustained vigilance.

Stage 3:

ZPA implementation marks a shift to identity-centric Zero Trust, neutralizing lateral movement and network-based attacks.

Future Scope:

Stage 1:

Increasing demand for web testing is driven by online growth and advanced technologies like AI and IoT.

Stage 2:

AI-driven testing and blockchain security represent the promising future of vulnerability discovery.

Stage 3:

Future scope includes SASE convergence, advanced posture checking, and AI-driven anomaly detection.

Topics Explored:

Zscaler, Zero trust, ZPA, VPN, MISP, College Network Information, Deployment of SOC, Threat Intelligence, Incident Response,Nessus Scanner.